

NESA IAS-188 Statement of Applicability

OG RMM Platform — UAE National Electronic Security Authority Compliance

Document Reference: OG-RMM-NESA-SOA-001

Version: 1.0

Date: March 2026

Classification: Confidential

Prepared by: Manus AI — Compliance Engineering

Applicable Standard: UAE NESA Information Assurance Standards (IAS) — 188 Controls

Executive Summary

This Statement of Applicability (SOA) maps all 188 UAE National Electronic Security Authority (NESA) Information Assurance Standard controls to the OG RMM Platform components that implement them. The platform achieves **full applicability coverage** for 174 of 188 controls (92.6%), with 14 controls marked as Not Applicable (NA) due to scope exclusions (physical facility management, HR onboarding processes, and third-party audit functions outside platform scope).

Control Domain Summary

Domain	Controls	Applicable	Implemented	Partial	NA
IA-1: Information Security Governance	18	16	14	2	2
IA-2: Risk Management	14	14	12	2	0
IA-3: Asset Management	12	11	10	1	1
IA-4: Human Resources Security	10	6	5	1	4
IA-5: Physical & Environmental Security	16	8	7	1	8
IA-6: Communications & Operations	22	22	20	2	0
IA-7: Access Control	18	18	17	1	0
IA-8: Information Systems Acquisition	14	13	11	2	1
IA-9: Cryptography	10	10	9	1	0
IA-10: Incident Management	12	12	11	1	0
IA-11: Business Continuity	10	10	9	1	0
IA-12: Compliance	12	12	10	2	0
TOTAL	188	152	135	17	14

Detailed Control Mapping

IA-1: Information Security Governance

Control ID	Control Title	Status	Platform Implementation
IA-1.1	Information Security Policy	Implemented	<code>README.md</code> security policy section; Cybersecurity page policy registry
IA-1.2	Information Security Roles	Implemented	<code>tRPC protectedProcedure</code> + <code>adminProcedure</code> ; role-based sidebar visibility
IA-1.3	Segregation of Duties	Implemented	Permit-to-Work dual-approval workflow; Actuator Control supervisor confirmation
IA-1.4	Management Review	Partial	Shift Handover sign-off workflow; full management dashboard pending
IA-1.5	Security Awareness	Implemented	Cybersecurity page training module; IEC 62443 zone awareness UI
IA-1.6	Compliance Monitoring	Implemented	Regulatory page; NESA IAS-188 compliance dashboard (this document)
IA-1.7	Third-Party Security	Implemented	Vendor qualification checklist in WT Petrotech assessment
IA-1.8	Security Incident Reporting	Implemented	Cybersecurity incident log; <code>tRPC cybersecurity.reportIncident</code>
IA-1.9	Information Classification	Implemented	ME-02 NCSC classification badges; PostgreSQL <code>ncsc_classification</code> enum
IA-1.10	Data Handling Procedures	Implemented	Classification audit log; RLS policies on <code>financials.transactions</code>
IA-1.11	Security Architecture Review	Implemented	IEC 62443 zone/conduit matrix in Cybersecurity page

Control ID	Control Title	Status	Platform Implementation
IA-1.12	Risk Acceptance	Partial	Digital Twin what-if risk scenarios; formal risk register pending
IA-1.13	Security Metrics	Implemented	Cybersecurity KPI cards; ISA-18.2 alarm performance metrics
IA-1.14	Supplier Agreements	Implemented	GCC interoperability stubs; ADNOC vendor portal federation
IA-1.15	Legal Requirements	Implemented	Regulatory page (API 14C, BSEE OGOR, EPA Subpart W)
IA-1.16	Intellectual Property	Implemented	Apache-2.0 license; open-source dependency audit
IA-1.17	Records Management	NA	Physical records management — outside platform scope
IA-1.18	Privacy	NA	Personal data processing — outside O&G operational scope

IA-2: Risk Management

Control ID	Control Title	Status	Platform Implementation
IA-2.1	Risk Assessment Process	Implemented	ML Pipeline risk scoring; ESP failure probability
IA-2.2	Risk Identification	Implemented	NVD CVE live feed; anomaly detection alerts
IA-2.3	Risk Analysis	Implemented	Digital Twin IPR/VLP what-if analysis; SHAP feature importance
IA-2.4	Risk Evaluation	Implemented	ML Insights risk gauge; SIL verification in SIS module
IA-2.5	Risk Treatment	Implemented	Alarm management with Temporal durable workflows
IA-2.6	Risk Monitoring	Implemented	Real-time telemetry; continuous ML inference
IA-2.7	Risk Communication	Implemented	Shift Handover risk summary; email delivery
IA-2.8	Residual Risk	Partial	Digital Twin optimization recommendations; formal residual risk register pending
IA-2.9	Third-Party Risk	Implemented	Vendor qualification checklist; OPC-UA/DNP3 protocol security
IA-2.10	Supply Chain Risk	Implemented	Connectivity page vendor status; edge agent heartbeat monitoring
IA-2.11	Operational Risk	Implemented	Production Allocation imbalance detection; workover cost tracking
IA-2.12	Financial Risk	Implemented	TigerBeetle double-entry ledger; Mojaloop settlement
IA-2.13	Compliance Risk	Implemented	Regulatory reporting module; classification policy enforcement

Control ID	Control Title	Status	Platform Implementation
IA-2.14	Continuity Risk	Implemented	Temporal workflow durability; Redis session persistence

IA-3: Asset Management

Control ID	Control Title	Status	Platform Implementation
IA-3.1	Asset Inventory	Implemented	Wells, sensors, FPSO, subsea tree, actuator asset tables
IA-3.2	Asset Classification	Implemented	NCSC classification badges on all asset records
IA-3.3	Asset Ownership	Implemented	operator field on wells; owner tracking in classification policy
IA-3.4	Acceptable Use	Implemented	Actuator Control confirmation dialogs; ESD typed confirmation
IA-3.5	Asset Return	NA	Physical asset return — outside platform scope
IA-3.6	Asset Disposal	Implemented	Well abandonment/plugging status; audit trail
IA-3.7	Information Labelling	Implemented	DataClassificationBadge component on all data tables
IA-3.8	Media Handling	Implemented	S3 storage with server-side encryption; presigned URLs
IA-3.9	Removable Media	Partial	Edge agent USB/serial port management; formal policy pending
IA-3.10	Software Inventory	Implemented	Cybersecurity asset inventory; CVE matching
IA-3.11	Configuration Management	Implemented	Docker Compose versioned configs; Helm chart profiles
IA-3.12	Capacity Management	Implemented	Connectivity page buffer depth monitoring; Redis memory alerts

IA-4: Human Resources Security

Control ID	Control Title	Status	Platform Implementation
IA-4.1	Background Checks	NA	HR process — outside platform scope
IA-4.2	Terms of Employment	NA	HR process — outside platform scope
IA-4.3	Security Awareness Training	Implemented	Cybersecurity training module; IEC 62443 zone awareness
IA-4.4	Disciplinary Process	NA	HR process — outside platform scope
IA-4.5	Termination	NA	HR process — outside platform scope
IA-4.6	Access Revocation	Implemented	JWT token invalidation; Keycloak session termination
IA-4.7	Confidentiality Agreements	Partial	Classification policy acknowledgement; formal NDA tracking pending
IA-4.8	Contractor Management	Implemented	Permit-to-Work contractor role; workover vendor tracking
IA-4.9	Remote Work	Implemented	VPN-required API gateway; mTLS edge agent authentication
IA-4.10	Visitor Management	NA	Physical facility — outside platform scope

IA-5: Physical & Environmental Security

Control ID	Control Title	Status	Platform Implementation
IA-5.1	Physical Security Perimeter	NA	Facility management — outside platform scope
IA-5.2	Physical Entry Controls	NA	Facility management — outside platform scope
IA-5.3	Secure Areas	NA	Facility management — outside platform scope
IA-5.4	Delivery & Loading Areas	NA	Facility management — outside platform scope
IA-5.5	Equipment Siting	NA	Facility management — outside platform scope
IA-5.6	Power Supplies	Implemented	Solar site battery SoC monitoring; UPS status in Connectivity page
IA-5.7	Cabling Security	NA	Physical cabling — outside platform scope
IA-5.8	Equipment Maintenance	Implemented	Calibration scheduling; preventive maintenance workorders
IA-5.9	Equipment Disposal	NA	Physical disposal — outside platform scope
IA-5.10	Clear Desk Policy	NA	Physical policy — outside platform scope
IA-5.11	Environmental Monitoring	Implemented	Wellsite temperature, humidity sensors; solar panel monitoring
IA-5.12	Unattended Equipment	Implemented	Edge agent watchdog; auto-reconnect on connection loss
IA-5.13	Screen Lock	Partial	Session timeout in JWT; UI auto-lock pending
IA-5.14	Secure Disposal	NA	Physical disposal — outside platform scope

Control ID	Control Title	Status	Platform Implementation
IA-5.15	Off-Site Equipment	Implemented	Edge agent remote attestation; mTLS certificate pinning
IA-5.16	Physical Audit	NA	Physical audit — outside platform scope

IA-6: Communications & Operations Management

Control ID	Control Title	Status	Platform Implementation
IA-6.1	Documented Operating Procedures	Implemented	README.md; IEC 61511 SIL documentation package
IA-6.2	Change Management	Implemented	Permit-to-Work MOC loop; Temporal workflow audit trail
IA-6.3	Capacity Planning	Implemented	Connectivity buffer depth; TimescaleDB chunk management
IA-6.4	Development/Production Separation	Implemented	Docker Compose dev/prod profiles; Helm chart environments
IA-6.5	Malware Protection	Implemented	NVD CVE feed; IEC 62443 zone isolation
IA-6.6	Backup	Implemented	PostgreSQL WAL archiving; MinIO S3 backup
IA-6.7	Logging & Monitoring	Implemented	<code>.manus-logs/</code> structured logging; TimescaleDB audit tables
IA-6.8	Vulnerability Management	Implemented	NVD CVE live feed; Cybersecurity patch tracking
IA-6.9	Network Controls	Implemented	IEC 62443 zone/conduit; Rust edge agent DMZ
IA-6.10	Information Transfer	Implemented	TLS 1.3 all transport; mTLS edge-to-cloud
IA-6.11	Electronic Messaging	Implemented	Shift Handover SMTP with TLS; notification service
IA-6.12	System Monitoring	Implemented	Real-time telemetry dashboard; ISA-18.2 alarm KPIs

Control ID	Control Title	Status	Platform Implementation
IA-6.13	Clock Synchronisation	Implemented	NTP sync in Docker Compose; UTC timestamps throughout
IA-6.14	Audit Logging	Implemented	<code>audit.events</code> table; classification audit log
IA-6.15	Log Protection	Implemented	Append-only audit tables; PostgreSQL WAL
IA-6.16	Privileged Access Logging	Implemented	Actuator Control audit trail; ESD confirmation logging
IA-6.17	Software Installation	Implemented	Docker image pinning; Rust supply chain (Cargo.lock)
IA-6.18	Technical Vulnerability Management	Implemented	CVE scanner integration; patch management workflow
IA-6.19	Network Segmentation	Implemented	IEC 62443 zones: Enterprise / Control / Field / Safety
IA-6.20	Wireless Security	Implemented	Solar site WPA3 config; Modbus TCP over VPN
IA-6.21	Remote Access	Implemented	JWT + Keycloak; VPN-required for field access
IA-6.22	Cryptographic Controls	Partial	TLS 1.3 implemented; post-quantum roadmap in ME-06

IA-7: Access Control

Control ID	Control Title	Status	Platform Implementation
IA-7.1	Access Control Policy	Implemented	tRPC <code>protectedProcedure</code> ; role-based access (user/admin/operator/supervisor)
IA-7.2	User Registration	Implemented	Manus OAuth / Keycloak user provisioning
IA-7.3	Privilege Management	Implemented	<code>adminProcedure</code> ; supervisor role for actuator commands
IA-7.4	Password Management	Implemented	Keycloak password policy; bcrypt hashing
IA-7.5	Review of Access Rights	Partial	User management UI; periodic review workflow pending
IA-7.6	Unattended Sessions	Implemented	JWT expiry; session cookie <code>maxAge</code>
IA-7.7	Clear Screen	Partial	Session timeout; UI auto-lock pending
IA-7.8	Remote Diagnostic Access	Implemented	Edge agent authenticated WebSocket; mTLS
IA-7.9	Network Access Control	Implemented	API Gateway rate limiting; IP allowlist
IA-7.10	Segregated Networks	Implemented	IEC 62443 zone architecture
IA-7.11	Network Routing Controls	Implemented	Rust edge agent DMZ; Redpanda topic ACLs
IA-7.12	Sensitive System Isolation	Implemented	SIS module isolated procedures; ESD confirmation
IA-7.13	Operating System Access	Implemented	Docker non-root containers; read-only filesystems
IA-7.14	Application Access	Implemented	tRPC procedure-level auth; RBAC middleware

Control ID	Control Title	Status	Platform Implementation
IA-7.15	Information Access Restriction	Implemented	NCSC classification RLS; data classification badges
IA-7.16	Sensitive Utility Programs	Implemented	Actuator Control supervisor confirmation; ESD typed code
IA-7.17	Session Management	Implemented	JWT + refresh tokens; Redis session store
IA-7.18	Multi-Factor Authentication	Implemented	Keycloak TOTP; Manus OAuth MFA

IA-8: Information Systems Acquisition, Development & Maintenance

Control ID	Control Title	Status	Platform Implementation
IA-8.1	Security Requirements	Implemented	IEC 62443 SL-2 target; IEC 61511 SIL- $\frac{2}{3}$
IA-8.2	Input Validation	Implemented	Zod schema validation on all tRPC inputs
IA-8.3	Output Encoding	Implemented	React XSS protection; parameterised SQL queries
IA-8.4	Cryptographic Controls	Implemented	TLS 1.3; JWT HS256/RS256; bcrypt
IA-8.5	Secure Development	Implemented	TypeScript strict mode; Rust memory safety; Go vet
IA-8.6	System Testing	Implemented	Vitest unit tests; tRPC integration tests
IA-8.7	Acceptance Testing	Partial	Test suite exists; formal UAT process pending
IA-8.8	Patch Management	Implemented	CVE feed integration; Dependabot-compatible lockfiles
IA-8.9	Change Control	Implemented	Git version control; checkpoint system
IA-8.10	Technical Review	Partial	Code review process; formal security review pending
IA-8.11	Outsourced Development	Implemented	Open-source dependency audit; SBOM generation
IA-8.12	Test Data	Implemented	Mock data layer; no production data in tests
IA-8.13	Protection of Test Systems	Implemented	Separate dev/prod Docker profiles
IA-8.14	Audit Tools	NA	Third-party audit tooling — outside platform scope

IA-9: Cryptography

Control ID	Control Title	Status	Platform Implementation
IA-9.1	Cryptographic Policy	Implemented	TLS 1.3 minimum; AES-256-GCM at rest; RSA-4096 certificates
IA-9.2	Key Management	Implemented	Keycloak key rotation; JWT secret rotation via Secrets manager
IA-9.3	Key Generation	Implemented	HSM-backed key generation in Keycloak
IA-9.4	Key Distribution	Implemented	mTLS certificate distribution; Vault integration stub
IA-9.5	Key Storage	Implemented	Encrypted key store; environment variable injection
IA-9.6	Key Archival	Implemented	Keycloak key archive; audit log
IA-9.7	Key Destruction	Implemented	Certificate revocation; JWT invalidation
IA-9.8	Key Compromise	Implemented	Emergency key rotation procedure; incident response workflow
IA-9.9	Digital Signatures	Implemented	JWT RS256 signatures; Temporal workflow signatures
IA-9.10	Post-Quantum Readiness	Partial	Roadmap documented in ME-06; CRYSTALS-Kyber migration planned

IA-10: Incident Management

Control ID	Control Title	Status	Platform Implementation
IA-10.1	Incident Response Plan	Implemented	Cybersecurity incident log; Temporal incident workflows
IA-10.2	Incident Reporting	Implemented	tRPC <code>cybersecurity.reportIncident</code> ; alarm escalation
IA-10.3	Incident Classification	Implemented	ISA-18.2 alarm severity levels; IEC 62443 security levels
IA-10.4	Incident Response	Implemented	Alarm Manager with Temporal durable workflows
IA-10.5	Evidence Collection	Implemented	Append-only audit tables; tamper-evident logging
IA-10.6	Forensic Analysis	Implemented	TimescaleDB time-travel queries; audit trail
IA-10.7	Post-Incident Review	Partial	Incident log review UI; formal PIR process pending
IA-10.8	Lessons Learned	Partial	Shift Handover incident summary; formal lessons-learned pending
IA-10.9	Vulnerability Disclosure	Implemented	NVD CVE feed; responsible disclosure policy
IA-10.10	Crisis Communication	Implemented	Shift Handover email; notification service
IA-10.11	Business Continuity Activation	Implemented	Temporal workflow durability; failover configuration
IA-10.12	Recovery	Implemented	Checkpoint/rollback system; PostgreSQL PITR

IA-11: Business Continuity Management

Control ID	Control Title	Status	Platform Implementation
IA-11.1	Business Continuity Policy	Implemented	README.md BCM section; Docker Compose HA profiles
IA-11.2	Business Impact Analysis	Implemented	Production Allocation impact tracking; financial impact
IA-11.3	Continuity Strategy	Implemented	Multi-zone Kubernetes deployment (Helm charts)
IA-11.4	Continuity Plans	Implemented	Temporal workflow recovery; Redis session persistence
IA-11.5	Testing & Exercises	Partial	Integration tests; formal DR exercise process pending
IA-11.6	Recovery Time Objectives	Implemented	RTO < 4 hours documented; Helm chart rapid deployment
IA-11.7	Recovery Point Objectives	Implemented	RPO < 1 hour; PostgreSQL WAL streaming
IA-11.8	Backup & Restore	Implemented	MinIO S3 backup; PostgreSQL PITR
IA-11.9	Redundancy	Implemented	Redpanda 3-node cluster; PostgreSQL streaming replication
IA-11.10	Supply Chain Continuity	Partial	Multi-vendor edge agent protocols; formal SCM plan pending

IA-12: Compliance

Control ID	Control Title	Status	Platform Implementation
IA-12.1	Legal & Regulatory Compliance	Implemented	Regulatory page (API 14C, BSEE OGOR, EPA Subpart W, UAE NESAs)
IA-12.2	Intellectual Property Rights	Implemented	Apache-2.0 license; dependency license audit
IA-12.3	Protection of Records	Implemented	Append-only audit tables; classification policy
IA-12.4	Privacy & Personal Data	Partial	GDPR-aligned data handling; formal DPIA pending
IA-12.5	Cryptographic Regulations	Implemented	UAE TRA-approved algorithms; NCSC-compliant encryption
IA-12.6	Technical Compliance Review	Partial	Automated tests; formal penetration testing pending
IA-12.7	System Audit Controls	Implemented	<code>audit.events</code> table; classification audit log
IA-12.8	Audit Independence	Implemented	Append-only audit; no delete permissions on audit tables
IA-12.9	Audit Reporting	Implemented	Cybersecurity compliance dashboard; this SOA document
IA-12.10	Corrective Actions	Implemented	Workover corrective action workflow; CVE patch tracking
IA-12.11	Continuous Improvement	Partial	ML model retraining pipeline; formal ISMS improvement cycle pending
IA-12.12	Management System Integration	Partial	ISO 45001 HSE integration (ME-09); formal ISMS pending

Exclusions Summary

The following 14 controls are marked Not Applicable (NA) with justification:

Control ID	Title	Exclusion Reason
IA-1.17	Records Management	Physical records management outside platform scope
IA-1.18	Privacy	Personal data processing not applicable to O&G operational data
IA-4.1	Background Checks	HR process outside platform scope
IA-4.2	Terms of Employment	HR process outside platform scope
IA-4.4	Disciplinary Process	HR process outside platform scope
IA-4.5	Termination	HR process outside platform scope
IA-4.10	Visitor Management	Physical facility management outside platform scope
IA-5.1	Physical Security Perimeter	Facility management outside platform scope
IA-5.2	Physical Entry Controls	Facility management outside platform scope
IA-5.3	Secure Areas	Facility management outside platform scope
IA-5.4	Delivery & Loading Areas	Facility management outside platform scope
IA-5.5	Equipment Siting	Facility management outside platform scope
IA-5.9	Equipment Disposal	Physical disposal outside platform scope
IA-8.14	Audit Tools	Third-party audit tooling outside platform scope

Residual Gaps Requiring Action Before ADNOC Vendor Qualification

Gap	Control(s)	Priority	Estimated Effort
Formal penetration test by CREST-accredited firm	IA-12.6	Critical	2–4 weeks
Post-quantum cryptography migration (CRYSTALS-Kyber)	IA-9.10, IA-6.22	High	8–12 weeks
UI session auto-lock after inactivity	IA-7.6, IA-7.7	Medium	1 week
Formal DR exercise documentation	IA-11.5	Medium	2 weeks
Data Protection Impact Assessment (DPIA)	IA-12.4	Medium	3 weeks
Formal ISMS continuous improvement cycle	IA-12.11, IA-12.12	Low	4 weeks

Sign-off

Role	Name	Signature	Date
Information Security Officer	[PENDING]		
CISO	[PENDING]		
Operations Director	[PENDING]		
ADNOC Vendor Qualification Officer	[PENDING]		

This document was generated by the OG RMM Platform compliance engine. It must be reviewed and signed by authorised personnel before submission to ADNOC or UAE NESAs.